

Taller práctico - Gestión de Riesgos

Grupo N° 6

Nombres: Isaac David Burgos, Gina Sofia Garcia, Jose Luis Lancheros

Escenario de análisis - Pérdida de un computador corporativo

Riesgo identificado

El riesgo principal es la fuga de información confidencial de la empresa y también el acceso no autorizado al sistema corporativo de la empresa lo que ocurre la pérdida de confidencialidad, integridad y disponibilidad de la información.

Uno de las amenazas es que los empleados trabajan desde lugares externos a la empresa lo que puede ocurrir es un robo o pérdida. La vulnerabilidad como el computador está en un lugar externo a la empresa, no hay un control inmediato en el sistema, por lo que existe la posibilidad de que puedan descargar información sensible de la empresa, incluso introducirle un virus para poder ser hackeado. Como hay una falta de estandarización confirmada en las configuraciones de seguridad y cifrado de los equipos.

Posibilidad y consecuencia

Posibilidad Alta (Valor 3): existe evidencia donde la empresa manifiesta tanto como el robo y pérdida de 4 computadores, lo que demuestra que las condiciones favorecen al evento y es una amenaza activa.

Consecuencia Grave (Valor 3): no tener certeza de que todos los equipos cuentan con el cifrado configurado correctamente, la pérdida de un dispositivo puede resultar en una fuga de datos.

Nivel de riesgo → Alta (4)

No hay línea base de configuración de seguridad ni revisión de permisos en el control de cambios, ni monitoreos de postura en la nube (CSPM). Existen escenarios automáticos que detectan recursos expuestos en pocos horas. El criterio de actuación es prioritario y seguimiento directo.

Impacto catastrófico (5) El activo contiene datos personales, contratos facturación y respaldos de bases de datos.

Nivel de riesgo inherente → Extremo No es aceptable según los criterios de NovaTech (solo admite Bajo y Moderado) por lo que requiere tratamiento inmediato.

Riesgo residual estimado → Moderado Tras aplicar bloqueos de acceso público, cifrado y revisión periódica de permisos.

Principales impactos

- 1) **Legales**: incumplimiento de ley 1591 de 2012; sanciones de la SIC hasta 2.000 SMLMV; obligación de notificar a los titulares afectados
- 2) **Finanzas**: penalidades económicas o multas por la exposición de información de clientes y datos personales.
- 3) **Reputacional**: pérdida de confianza por parte de clientes, daño a la marca, dificultad para cerrar nuevas negocios.
- 4) **Operacional**: Retrasos en el desarrollo de software o la atención a clientes mientras el empleado afectado se encuentra sin equipo de trabajo

Tratamiento y controles propuestos

- 1) **Estandarización técnica**: implementar una solución de gestión de dispositivos móviles para homologar y obligar el cifrado de disco completo en el 100% de los computadores
- 2) **Botón remoto**: habilitar capacidades tecnológicas para enviar un comando de destrucción de datos al equipo en el momento en el usuario lo reporte como perdido
- 3) **Requisitos para ingresar**: para el acceso a todas las plataformas desde cualquier equipo dependa de autenticación multifactor.
- 4) **Simulacros de respuesta**: Realizar pruebas trimestrales simulando la pérdida de un equipo para medir cuánto tiempo tarda el empleado en reportarlo y cuánto tarda el equipo de seguridad en ejecutar el comando de borrado remoto.